Lloyds Banking Group

Andrew Buchanan – Security Consultancy & Design

Agentic AI: Curiosity Without Autonomy

PART 2

(Part 1 was RAG in 2025)

Also Follows on from :

- Chris Davies' LLM vulnerability scanning
- Megh & Phil's AI Standard
- Ants CVE Presentation

Who am I?

Engineering background
(civil → software → security)

Sometimes is better to do something to understand, and that's experience.

Objectives

Build something to try out Agentic AI.

Roadmap

Today I will cover

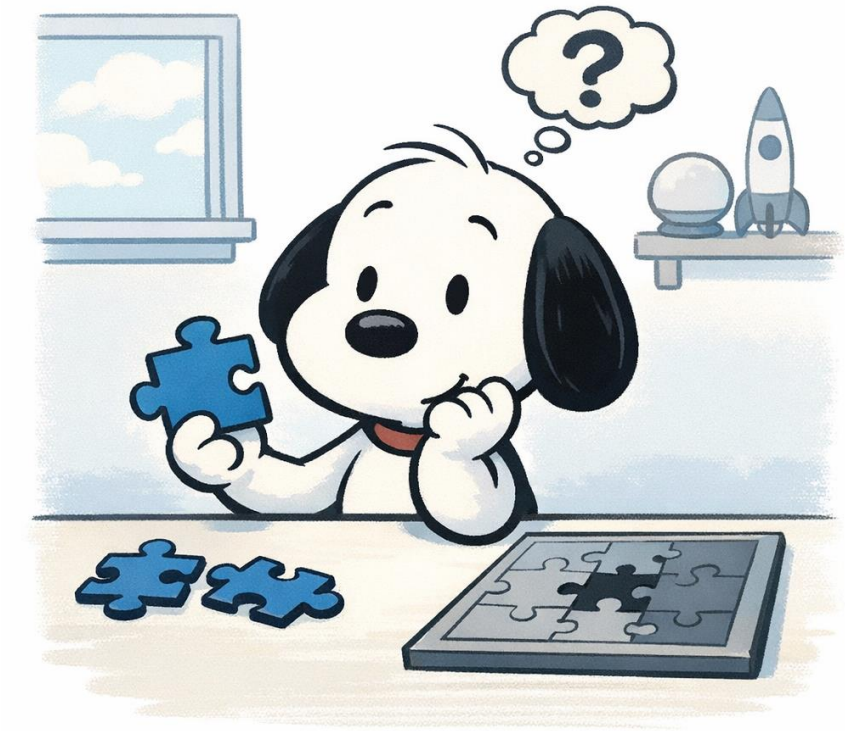
- Define Agentic AI
- Agency vs Control
- Build & Constraints
- What Broke
- Governance & LBG Alignment
- Live Demo

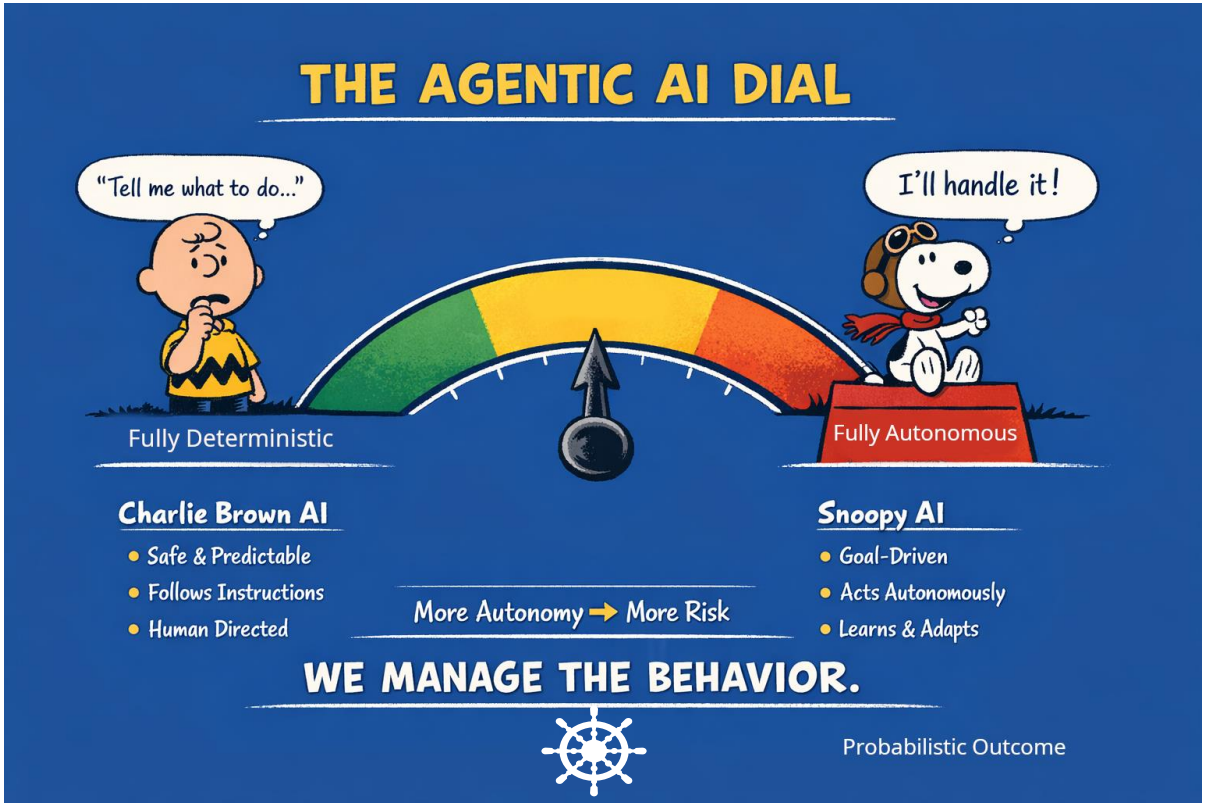
What I mean by Agentic AI

Observe
choose an action
call a constrained tool
Reason
Stop
Curiosity ≠ autonomy

Agency is the ability to choose and act.

Autonomy is the ability to self-direct without external control.





What's Snoopy got to do with this anyway?

What I built

What is it?

- Agentic security reconnaissance assistant
- Target: OWASP Juice Shop
- Limited tools
- Local build
- Hard guardrails
- Controller enforced stopping

What is it made of?

Architecture

Compute
- HP Z640
- Dual Xeon CPU's
- 256GB RAM
- RTX 2080 Ti
- Ubuntu 22.04

AI Runtime
- Ollama (local model execution)
- Llama (reasoning model)

Agent Layer
- Python
- FastAPI (tool interface layer)
- Deterministic logic controller (policy, gaurdrails, limits)

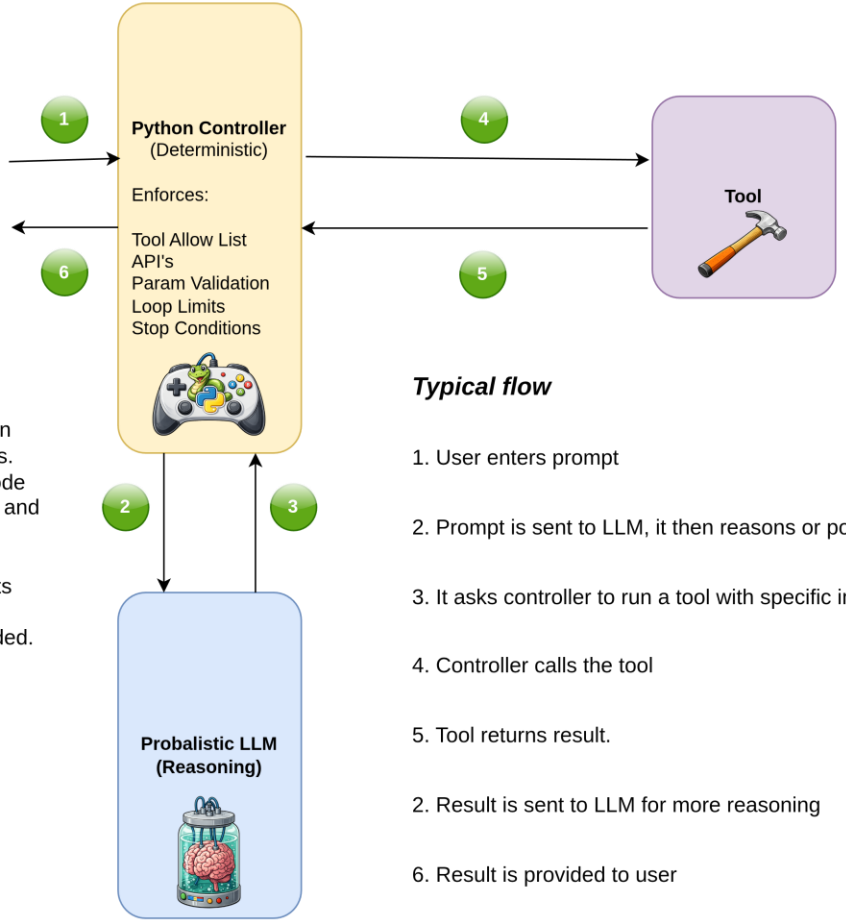
Target
- OWASP Juice Shop (Docker container)

Network
- Local-only execution
- No external API's

How I wrote the code ?

- AI-assisted rapid prototyping and iteration
- Natural language used to generate scaffolding
- Deterministic controller and guardrails designed intentionally
- Manual review, refactoring, and validation throughout
- Development accelerated — accountability unchanged

How this works



The LLM can reason and propose actions. But deterministic code enforces loop limits and stop conditions.

That's what prevents autonomy from becoming open-ended.

Typical flow

1. User enters prompt

2. Prompt is sent to LLM, it then reasons or ponders the problem.

3. It asks controller to run a tool with specific inputs.

4. Controller calls the tool

5. Tool returns result.

2. Result is sent to LLM for more reasoning

6. Result is provided to user

Three Decision Layers in the System

Deterministic

- Policy enforcement
- Guardrails
- Stop conditions

Probabilistic

- Interpretation
- Evidence analysis
- Summarisation

Agentic

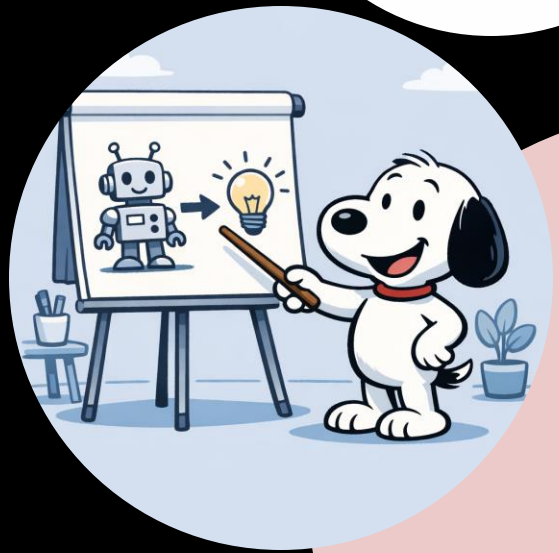
- Action selection
- Choosing next allowed step
- Exploration within limits

Phil and Megh's AI Guidance

LBG AI Principle	What it means in practice	How this build aligns
Human accountability	AI supports decisions; humans remain responsible	Recon output is advisory only; no automated decisions
Bounded autonomy	AI operates within defined limits	Deterministic controller + enforced stop conditions
Explainability	Actions must be understandable and reviewable	Tool calls and reasoning observable in workflow
Least privilege	Access restricted to minimum necessary capability	Allow-listed tools; local-only runtime
Data governance	Controlled handling of sensitive data	No external access; no secret extraction; preview-only file triage
Secure build patterns	AI systems must follow secure SDLC controls	Fixed tool interfaces; explicit scope; execution validation
Risk-based escalation	Human review before higher-risk actions	Explicit hand-off in “Recommended Next Steps”
Model governance	Controlled model sourcing and execution	Local model runtime; no external API calls

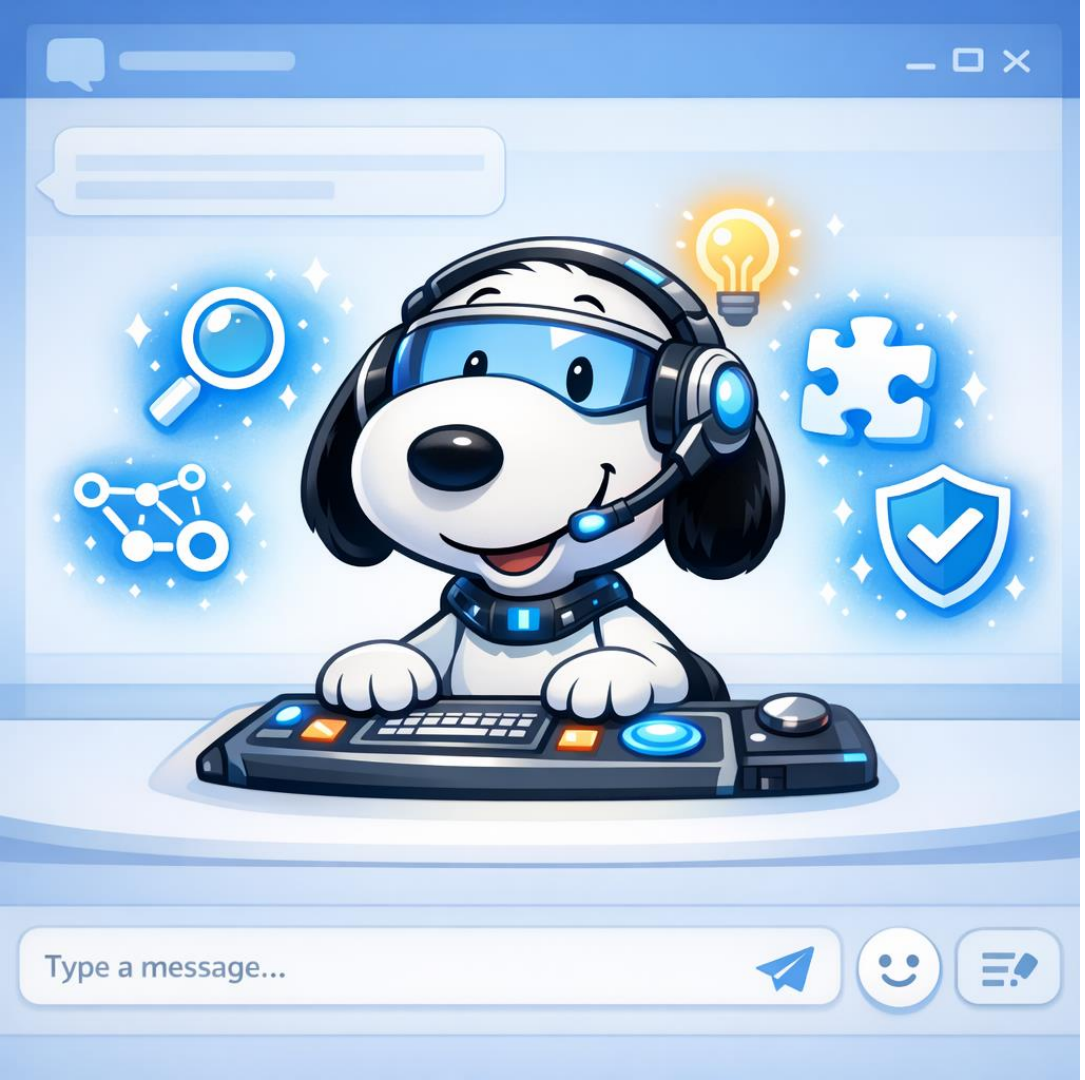
Live demo

- Prompt – "Recon Juice-Shop”



Whats Going on in Lloyds

- The Business defines the use case and decides where autonomy is acceptable.
- Cortex provides governed access to approved LLMs through a single API.
- Envoy is the future golden path to build and run agents safely, by providing the patterns and infrastructure necessary.
- PRISM enables controlled GenAI through predefined prompts and safety checks. (Document Summerisation)
- Responsible AI defines guardrails and assurance requirements.
- Enabling platforms set the technical ceilings for what agents can do.



Please feel to reach out after this call if there is anything that you would like to know.

https://github.com/BUCHAAE/agentic-demo